Blink-Kamerabilder

Lernunterlage: Kamerabilder sicher anzeigen – Proxy, Token, Object-URLs und Datenschutz

1 Worum es geht

Die Übersicht und die Blink-Seite zeigen jetzt pro Kamera Name, Online, Akku und das **letzte Vorschaubild** mit „Aufnahme von …“. Kamerabilder sind besonders schützenswert: Sie zeigen das Innere einer Wohnung. Deshalb gelten strengere Regeln als für Lampen und Steckdosen.

2 Proxy statt Direktlink

Blink liefert im Homescreen nur einen **Pfad** zum Bild. Abrufen kann ihn nur, wer ein gültiges **Blink-Token** mitschickt. Zwei Wege:

	Direktlink (nicht gewählt)	Proxy (gewählt)
Wer holt das Bild bei Blink?	der Browser	unser Backend
Wo liegt das Blink-Token?	im Browser (JavaScript, Netzwerk-Tab)	nur im Backend
Wer darf das Bild sehen?	jeder, der Token und Pfad kennt	nur wer bei Home Control angemeldet ist
Rate Limit, Cache, Protokoll	nicht möglich	an einer Stelle im Backend



> Ein Token im Browser ist wie ein Hausschlüssel unter der Fußmatte: Jedes Skript, jede Erweiterung und jeder, der über die Schulter schaut, kann ihn mitnehmen. Mit dem Blink-Token könnte man das ganze Kamerakonto lesen, nicht nur ein Bild.

3 Der Endpunkt

```
blink.MapGet("/cameras/{id:long}/thumbnail", GetThumbnail)
    .RequireAuthorization(AuthPolicies.SignedInUser)       // nur JWT
    .RequireRateLimiting(RateLimitPolicies.BlinkThumbnails); // 30 pro Minute

http.Response.Headers.CacheControl = "no-store";             // nicht zwischenspeichern
return Results.File(thumbnail.Content, thumbnail.ContentType);
```

- **Nur Menschen:** Die Policy `SignedInUser` akzeptiert nur das JWT aus dem Login. Der API-Schlüssel des KI-Agenten bekommt 401, auch wenn Lesen sonst ohne Anmeldung erlaubt ist.
- **no-store:** Das Bild landet nicht im Browser-Cache und nicht in einem Proxy dazwischen.
- **Kein neues Foto:** Nur GET auf das vorhandene Bild. Ein neues Foto würde die Akku-Kamera wecken.
- **Schutz für Blink:** Bilder 60 Sekunden im Server-Cache, dazu ein eigenes Rate Limit.

- **Aufnahmezeit:** im Header `X-Thumbnail-Taken-At`, aus dem Zeitstempel im Bildpfad.

4 Dem Pfad von Blink nicht blind vertrauen

Der Pfad kommt aus einer fremden Antwort. Würde das Backend ihn ungeprüft aufrufen, könnte eine manipulierte Antwort es zu einem fremden Server schicken – mit unserem Token im Header (**SSRF**, Server-Side Request Forgery). Deshalb:

- Nur **relative** Pfade (beginnen mit /), angehängt an `https://rest-{tier}.immedia-semi.com`.
- Kein `..`, kein `://`, kein `//` am Anfang, keine Leerzeichen.
- Nur `image/jpeg` oder `image/png` weiterreichen, höchstens 5 MB.

5 Im Browser: fetch und Object-URLs

Ein `<img src="/api/…/thumbnail">` kann keinen `Authorization`-Header mitschicken. Das Bild wird deshalb mit `fetch` geladen (unser `send()` hängt das Access Token an) und als **Object-URL** angezeigt:

```
getBlinkThumbnail(camera.id).then(({ image }) => {
  objectUrl = URL.createObjectURL(image)   // "blob:…", zeigt auf die Bytes
  setImageUrl(objectUrl)
})
return () => {                              // Seite verlassen oder neues Bild
  ignore = true
  if (objectUrl !== null) URL.revokeObjectURL(objectUrl)   // Speicher freigeben
}
```

- Eine Object-URL gilt nur in diesem Tab und nur, solange sie nicht freigegeben wurde.
- Ohne `revokeObjectURL` bleiben die Bilddaten im Speicher, bei jedem Neuladen mehr (Speicherleck).
- **ignore**: Kommt die Antwort erst, nachdem die Seite verlassen wurde, wird sie verworfen.

6 Datenschutz bei Kamerabildern

Grundsatz	Umsetzung in Home Control
Datensparsamkeit	Nur das letzte Vorschaubild, keine Videos, kein Archiv
Speicherbegrenzung	Kein Bild auf der Festplatte, nur 60 s im Arbeitsspeicher; no-store im Browser
Zugriffsschutz	Nur angemeldete Menschen (JWT), nicht der KI-Agent
Keine Spuren im Log	Nur maskierte Form des Pfads (Ziffern als #), nie Bild, Pfad oder Token
Zweckbindung	Anzeigen, ob zu Hause alles in Ordnung ist. Keine Auswertung, keine Weitergabe

Bei Tests mit echten Daten wird das Bild bewusst nicht angesehen: Geprüft werden nur Größe, Typ und Aufnahmezeit. Kameras, die öffentliche Bereiche oder Nachbarn erfassen, unterliegen zusätzlichen Regeln (DSGVO).

7 Die inoffizielle API als Risiko

- Blink hat keine öffentliche API. Am 02.11.2026 lehnte Blink die Bibliothek Blink.NET mit „426 Upgrade Required“ ab; Home Control nutzt seitdem einen eigenen Client nach dem Vorbild von blinkpy.
- Ändert Blink Adressen oder Felder, gibt es keine Vorwarnung. Die Karte zeigt dann ehrlich „Blink: derzeit nicht verfügbar“ statt eines Fehlers.
- Zwei Bildformate (Zeitstempel oder Pfad) werden unterstützt, weil Blink beide benutzt.

8 Grenzen

- Nur das **letzte** Bild: Es kann Stunden alt sein, deshalb steht die Aufnahmezeit dabei.
- Beim alten Bildformat ist die Aufnahmezeit unbekannt.
- Online nur bei eindeutigem Status (online/offline), sonst „unbekannt“; Temperatur noch nicht angezeigt.
- Ein Prozess pro Datenbank: Beim Entwickeln ist Blink aus.

9 Tests

Test	prüft
Ohne_Anmeldung_401 / Mit_Agenten_Schluessel_401	nur Menschen mit JWT
Mit_Anmeldung_wird_das_Bild_durchgereicht	image/jpeg, no-store, Aufnahmezeit-Header
Fehler_von_Blink_ergibt_verstaendliche_Meldung_statt_500	502 mit deutschem Text
Altes_/Neues_Bildformat_…	richtige Adresse, nur GET, unser Token
Verdaechtiger_Pfad_…	kein Aufruf eines fremden Servers
Bild_wird_60_Sekunden_vorgehalten	Server-Cache
Bild_bei_401_einmal_erneuern_dann_Fehler	keine Schleife
Keine_Bilddaten_von_Blink_ergeben_einen_Fehler	HTML-Fehlerseite wird nicht als Bild ausgegeben

10 Kurzantworten für Rückfragen

Frage	Antwort
Warum lädt der Browser das Bild nicht direkt bei Blink?	Dafür bräuchte er das Blink-Token. Das bleibt im Backend.
Warum fetch statt img src?	img kann keinen Authorization-Header schicken.
Was ist eine Object-URL?	Eine blob:-Adresse auf Bilddaten im Speicher dieses Tabs. Muss freigegeben werden.
Warum no-store?	Kamerabilder sollen nirgends liegen bleiben.
Warum darf der KI-Agent keine Bilder?	Bilder sind sensibler als Messwerte. Nur angemeldete Menschen.
Was ist SSRF?	Der Server wird dazu gebracht, eine fremde Adresse aufzurufen. Hier verhindert durch Pfadprüfung.

11 Merksätze

- Fremde Tokens bleiben im Backend, der Browser bekommt nur das Ergebnis (Proxy).
- Kamerabilder: nur angemeldet, no-store, nichts speichern, nichts loggen.
- Adressen aus fremden Antworten prüfen, bevor man sie aufruft (SSRF).
- Object-URLs immer mit revokeObjectURL freigeben.
- Bei einer inoffiziellen API ehrlich anzeigen, wenn sie nicht verfügbar ist.